CTF EMPIRE LUPIN ONE

Report Tecnico di Penetration Testing

Categoria: CTF / Boot2Root | Data: 23 Aprile 2026 | Livello: Principiante/Intermedio

1. Informazioni Generali

Target IP	192.168.64.17
Attacker IP	192.168.64.12
Sistema Operativo	Linux Debian (LupinOne) - Kernel 5.10.0-8-amd64
Servizi Trovati	SSH (22/tcp), HTTP (80/tcp)
Flag Utente	3mp!r3{I_See_That_You_Manage_To_Get_My_Bunny}
Obiettivo	Accesso iniziale come icex64, escalation privilegi a root

Questa CTF simula una macchina Linux vulnerabile denominata Empire: LupinOne. L'obiettivo e' quello di ottenere accesso alla macchina sfruttando una serie di vulnerabilita' e informazioni esposte, procedendo poi all'escalation dei privilegi per ottenere il controllo completo del sistema.

2. Fase 1 — Ricognizione della Rete (Network Scanning)

2.1 Host Discovery

Il primo passo e' stato identificare gli host attivi nella rete locale. E' stato utilizzato nmap con il flag -sn (ping scan, nessuna scansione delle porte) per mappare la subnet 192.168.64.0/24:

```
nmap -sn 192.168.64.0/24
```

Risultati ottenuti:

- 192.168.64.1 — Gateway di rete
- 192.168.64.17 — Host target (MAC: 72:E4:42:27:FF:05)
- 192.168.64.12 — Macchina attaccante (Kali Linux)

Il target identificato e' 192.168.64.17.

2.2 Port Scanning e Service Enumeration

Successivamente e' stata eseguita una scansione approfondita dei servizi attivi sul target con i flag -sV (version detection) e -sC (script di default NSE):

```
nmap -sV -sC 192.168.64.17
```

Risultati della scansione:

Porta 22/tcp	`OpenSSH 8.4p1 Debian 5 (protocol 2.0)`
Porta 80/tcp	`Apache httpd 2.4.48 (Debian)`
robots.txt	`1 entry disabilitata: /~myfiles`
OS Rilevato	`Linux, CPE: cpe:/o:linux:linux_kernel`

Di particolare interesse e' la voce robots.txt che rivela un percorso nascosto /~myfiles, suggerendo la presenza di directory utente accessibili via web (userdir module di Apache).

3. Fase 2 — Enumerazione Web

3.1 Directory Busting con Gobuster

E' stata eseguita una enumerazione delle directory e dei file sul web server usando Gobuster con la wordlist common.txt di dirb, ricercando file con estensioni comuni:

```
gobuster dir -u http://192.168.64.17/ -w /usr/share/wordlists/dirb/common.txt -x
php,txt,html,bak,zip
```

I risultati piu' significativi:

- index.html — Status 200, pagina principale
- robots.txt — Status 200, conferma la presenza della entry /~myfiles
- /image/ — Status 301 (redirect)
- /javascript/ — Status 301 (redirect)

- /manual/ — Status 301 (redirect)

Il file robots.txt (consultato dal browser) contiene:

```
User-agent: *
Disallow: /~myfiles
```

3.2 Fuzzing delle UserDir con ffuf

La presenza del modulo Apache UserDir e' stata confermata. E' stato quindi usato ffuf per fare fuzzing sull'endpoint /~FUZZ al fine di scoprire nomi utente validi (home directory pubbliche):

```
ffuf -u http://192.168.64.17/~FUZZ -w /usr/share/wordlists/dirb/common.txt
```

ffuf ha rilevato il seguente risultato positivo:

- **secret — Status 301, Size 316 → http://192.168.64.17/~secret/**

3.3 Analisi della Directory /~secret/

Navigando all'URL http://192.168.64.17/~secret/ e' stata trovata una pagina con il seguente messaggio lasciato dall'utente icex64:

"Hello Friend, Im happy that you found my secret directory, I created like this to share with you my create ssh private key file, Its hided somewhere here, so that hackers dont find it and crack my passphrase with fasttrack. I'm smart I know that. Any problem let me know — Your best friend icex64"

Questo messaggio rivela informazioni critiche: l'utente ha nascosto la sua chiave privata SSH in questa directory e ha indicato esplicitamente di NON aver usato 'fasttrack' come wordlist per la passphrase. Questo e' un indizio fondamentale per la fase successiva.

3.4 Recupero della Chiave Privata SSH

Esplorando il contenuto della directory /~secret/ e' stato trovato un file contenente dati encodati in base64. Tramite un script Python (decode.py) il contenuto e' stato decodificato e salvato come chiave privata SSH:

```
python3 /tmp/decode.py

# Output: Salvato in /tmp/id_rsa
```

```
cat /tmp/id_rsa
```

Il file contiene una chiave privata OpenSSH in formato standard (BEGIN OPENSSH PRIVATE KEY / END OPENSSH PRIVATE KEY). La chiave e' protetta da passphrase.

4. Fase 3 — Accesso Iniziale (Initial Access)

4.1 Cracking della Passphrase con John the Ripper

La chiave privata SSH e' protetta da passphrase. E' stato usato ssh2john per estrarre l'hash della passphrase, e poi John the Ripper per craccarla. Coerentemente con il suggerimento trovato nel messaggio, e' stata usata la wordlist fasttrack.txt:

```
ssh2john /tmp/id_rsa > /tmp/hash.txt

john /tmp/hash.txt --wordlist=/usr/share/wordlists/fasttrack.txt
```

John the Ripper ha individuato la passphrase in pochi secondi:

Passphrase trovata	`P@55w0rd!`
Algoritmo	`RSA/DSA/EC/OPENSSH 32/64`
Costo KDF	`Bcrypt/AES (Cost 2 = 16 iterazioni)`
Tempo impiegato	`~2 secondi`

Nota: l'utente icex64 aveva detto di non aver usato fasttrack, ma la password P@55w0rd! e' effettivamente presente in quella wordlist. Un esempio di ingegneria sociale inversa (false hint).

4.2 Connessione SSH

Con la chiave privata e la passphrase trovate, e' stato possibile connettersi come utente icex64:

```
chmod 600 id_rsa
```

```
ssh -i id_rsa icex64@192.168.64.17

# Enter passphrase: P@55w0rd!
```

L'accesso SSH e' riuscito con successo. Il sistema ha mostrato il banner:

```
Welcome to Empire: Lupin One

Linux LupinOne 5.10.0-8-amd64 #1 SMP Debian 5.10.46-5 (2021-09-23) x86_64
```

5. Fase 4 — Post-Exploitation e Flag Utente

5.1 Enumerazione della Home Directory

Una volta ottenuto l'accesso come icex64, e' stata esplorata la home directory:

```
ls -la
```

File presenti nella home:

- .bash_history (115 bytes) — cronologia dei comandi
- .bashrc, .bash_logout, .profile — file di configurazione shell
- .local/ — directory locale applicazioni
- .ssh/ — directory con chiavi SSH
- user.txt (2801 bytes) — FILE CONTENENTE LA FLAG

5.2 Lettura della Flag Utente

Il file user.txt contiene la flag utente, preceduta da un'ASCII art:

```
cat user.txt
```

La flag e':

```
3mp!r3{I_See_That_You_Manage_To_Get_My_Bunny}
```

6. Vulnerabilita' Identificate

VULN-01	Esposizione di informazioni in robots.txt — Rivela percorsi nascosti sensibili
VULN-02	Apache UserDir abilitato — Permette di enumerare utenti di sistema via /~username
VULN-03	Chiave SSH privata esposta su web — La chiave privata era accessibile via HTTP
VULN-04	Passphrase debole — P@55w0rd! e' presente nelle wordlist comuni
VULN-05	False hint nel messaggio — Indicazione fuorviante sull'assenza di fasttrack

7. Strumenti Utilizzati

nmap	Network scanning e service detection
gobuster	Directory e file enumeration su web server
ffuf	Fuzzing delle user directory Apache
python3	Decodifica base64 della chiave SSH
ssh2john	Estrazione hash dalla chiave SSH protetta
john	Cracking della passphrase (John the Ripper)
ssh	Accesso remoto al target

8. Timeline dell'Attacco

Step 1	Ping scan della rete → identificazione target 192.168.64.17
Step 2	Port scan con nmap → porte 22 (SSH) e 80 (HTTP) aperte

Step 3	`Gobuster → robots.txt rivela /~myfiles`
Step 4	`ffuf → scoperta della directory /~secret/`
Step 5	`Analisi /~secret/ → trovata chiave privata SSH encodata in base64`
Step 6	`Decodifica base64 → id_rsa salvata`
Step 7	`ssh2john + john → cracking passphrase: P@55w0rd!`
Step 8	`ssh -i id_rsa icex64@192.168.64.17 → accesso`
Step 9	`cat user.txt → flag: 3mp!r3{I_See_That_You_Manage_To_Get_My_Bunny}`

9. Conclusioni

La macchina CTF Empire: LupinOne ha dimostrato come una serie di vulnerabilita' apparentemente minori possano, se concatenate, portare alla compromissione completa di un sistema. La catena di attacco (attack chain) puo' essere riassunta come segue:

- Information Disclosure (robots.txt + Apache UserDir) → scoperta della directory nascosta
- Exposed Credentials (chiave SSH su HTTP) → recupero del materiale crittografico
- Weak Passphrase → cracking in pochi secondi con wordlist standard
- Unauthorized Access → shell come utente icex64

Lezione principale: non basta proteggere con crittografia un file sensibile se poi viene esposto su un canale pubblico come HTTP. Inoltre, le passphrase devono essere robuste e non basarsi su pattern prevedibili.